



FILE PATH TRAVERSAL

**TRAVERSAL SEQUENCES BLOCKED
WITH ABSOLUTE PATH BYPASS**

ACTIVIDAD 08

Indice

File Path Traversal: <i>Traversal Sequences Blocked with Absolute Path Bypass</i>	2
Especificaciones del laboratorio.....	2
Objetivo del laboratorio	2
Marco Teórico	3
Mecanismo del filtro y su bypass mediante ruta absoluta	3
Clasificación según OWASP Top 10 y triada CIA.....	3
Riesgos en un entorno real.....	3
Procedimiento	4
Explicación del Payload	7
Mitigación recomendada	7
Referencias.....	8

File Path Traversal: *Traversal Sequences Blocked with Absolute Path Bypass*

Especificaciones del laboratorio

Laboratorio: File Path Traversal, Traversal Sequences Blocked with Absolute Path Bypass

Nivel: Practitioner

Tipo de explotación: File Path Traversal, bypass de un filtro anti-traversal mediante ruta absoluta

Objetivo del laboratorio

Recuperar el contenido del archivo `/etc/passwd` en una aplicación que sí implementa un filtro contra secuencias de traversal (`../`), demostrando que dicho filtro puede eludirse proporcionando directamente una ruta absoluta en el parámetro `filename`, sin necesidad de usar secuencias de retroceso de directorio. El objetivo académico es identificar, mediante interceptación de tráfico con Burp Suite, un punto donde la entrada del usuario se concatena sin validar a una ruta del sistema de archivos, y demostrar cómo esa falta de saneamiento permite escapar del directorio autorizado.

Marco Teórico

Mecanismo del filtro y su bypass mediante ruta absoluta

A diferencia del simple case, esta página sí intenta defenderse ya que detecta y bloquea la secuencia "../" antes de resolver la ruta del archivo. Sin embargo, esta defensa parte de un supuesto de que el valor recibido siempre será una ruta relativa a la carpeta donde se almacenan las imágenes.

El propio PortSwigger documenta esta clase de bypass como uno de los obstáculos comunes al explotar path traversal, cuando el filtro bloquea únicamente secuencias de retroceso, suele ser posible usar una ruta absoluta desde la raíz del sistema de archivos, como filename=/etc/passwd, para referenciar el archivo directamente, sin recurrir a ninguna secuencia de traversal (*PortSwigger, s.f.*).

La causa técnica es que muchas funciones de manejo de rutas en distintos lenguajes de descartan por completo el directorio de base cuando la entrada recibida ya es una ruta absoluta que es cuando comienza con "/". En ese caso, la función no concatena ambos valores, sino que regresa únicamente la ruta absoluta que le fue dada. El filtro anti-traversal, diseñado para detectar patrones como "../", no se activa, porque el payload /etc/passwd no contiene ninguna secuencia de ese tipo, ya que es sólo una ruta completa y válida que la función de resolución de rutas interpreta de forma literal, ignorando la carpeta de imágenes que debía usar.

Clasificación según OWASP Top 10 y triada CIA

Al igual que en el caso simple, esta vulnerabilidad corresponde a la categoría **A01:2025 – Broken Access Control del OWASP Top 10 de 2025**, la categoría de mayor incidencia registrada, presente en el 100% de las aplicaciones evaluadas (OWASP Foundation, 2025), y sigue mapeada a CWE-22 (MITRE Corporation, 2024). La diferencia relevante frente al caso simple no es la categoría, sino la robustez de la defensa, aquí el desarrollador sí intentó mitigar la falla, pero implementó una validación incompleta que cubre un solo vector de ataque (retroceso de directorio) y pasa por alto otro (ruta absoluta).

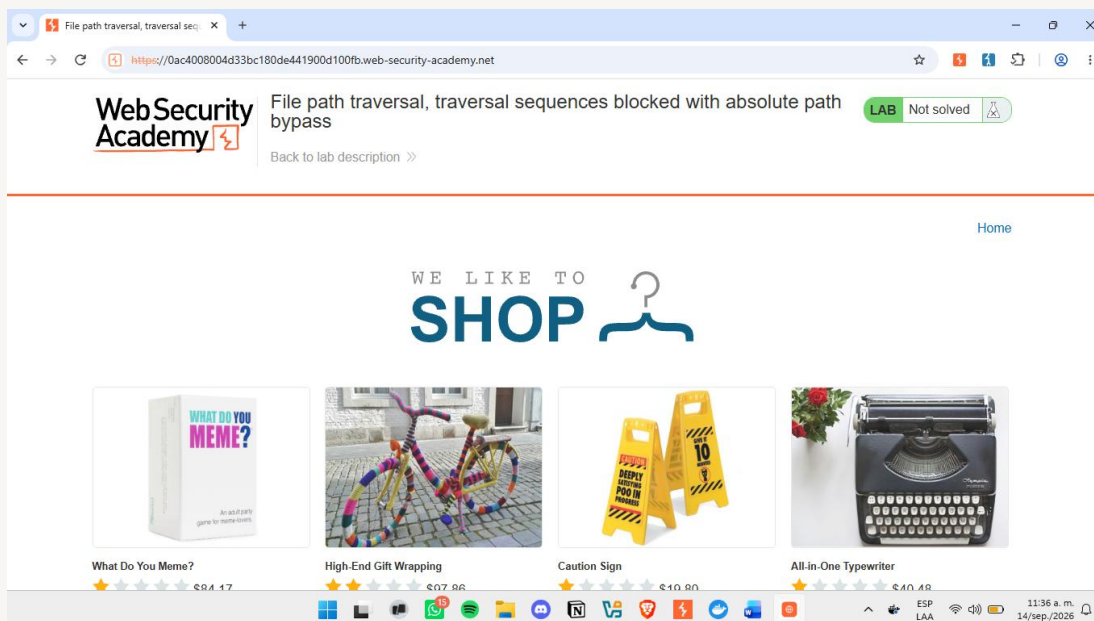
El impacto sobre la triada CIA es idéntico al del caso simple es comprometer la Confidencialidad al exponer archivos internos del servidor. Lo que cambia es el fondo, pues un control de seguridad basado en bloquear patrones específicos (blacklist) es inherentemente frágil, porque solo cubre los vectores que el desarrollador anticipó.

Riesgos en un entorno real

Este patrón de filtrado incompleto es común en aplicaciones reales que intentan parchear un path traversal detectado en una auditoría previa, bloqueando únicamente la cadena "../" sin revisar rutas absolutas ni otras variantes de codificación. El riesgo práctico es que el equipo de desarrollo puede dar por cerrada la vulnerabilidad tras una prueba superficial, dejando expuesto el mismo archivo /etc/passwd, /etc/shadow o archivos de configuración internos ante cualquier atacante que pruebe una ruta absoluta directa.

Procedimiento

1. Se accedió a la instancia del laboratorio provista por PortSwigger utilizando el navegador Chromium integrado de Burp Suite, verificando el estado inicial "Not solved".



2. Al navegar el catálogo de productos, se revisó la pestaña Proxy > HTTP history de Burp Suite, donde se identificaron múltiples peticiones GET dirigidas al endpoint /image, cada una con un parámetro filename distinto (filename=55.jpg, filename=72.jpg, filename=36.jpg, etc.).

#	Host	Meth...	URL
457	https://0a79004d03819a68803ea3dd...	GET	/image?filename=55.jpg
459	https://0a79004d03819a68803ea3dd...	GET	/image?filename=72.jpg
461	https://0a79004d03819a68803ea3dd...	GET	/image?filename=36.jpg
465	https://0a79004d03819a68803ea3dd...	GET	/image?filename=61.jpg
466	https://0a79004d03819a68803ea3dd...	GET	/image?filename=4.jpg
467	https://0a79004d03819a68803ea3dd...	GET	/image?filename=66.jpg
468	https://0a79004d03819a68803ea3dd...	GET	/image?filename=49.jpg
469	https://0a79004d03819a68803ea3dd...	GET	/image?filename=6.jpg
470	https://0a79004d03819a68803ea3dd...	GET	/image?filename=29.jpg
471	https://0a79004d03819a68803ea3dd...	GET	/image?filename=33.jpg
472	https://0a79004d03819a68803ea3dd...	GET	/image?filename=20.jpg

3. Se seleccionó una de estas peticiones y se envió al módulo Repeater mediante el menú contextual (Send to Repeater)

The top screenshot shows the Burp Suite interface with the HTTP history tab selected. A list of requests is displayed, and a context menu is open over the selected request, showing options like 'Send to Repeater' (Ctrl+R) and 'Send to Sequencer'. The bottom screenshot shows the Repeater tab with the selected request loaded. The request details are visible on the left, and the response is on the right. The target URL is https://0a79004d03819a68803ea3dd004500cc.web-security-academy.net.

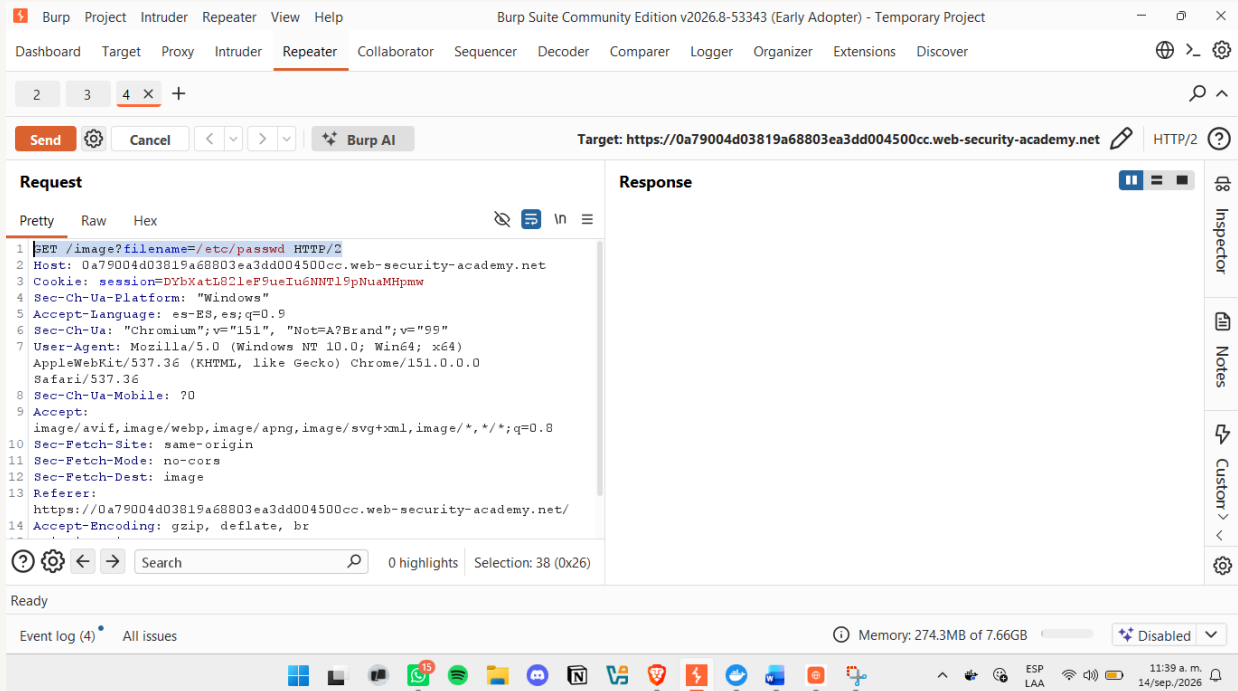
Request

```
1 GET /academyLabHeader HTTP/2
2 Host: 0a79004d03819a68803ea3dd004500cc.web-security-academy.net
3 Connection: Upgrade
4 Pragma: no-cache
5 Cache-Control: no-cache
```

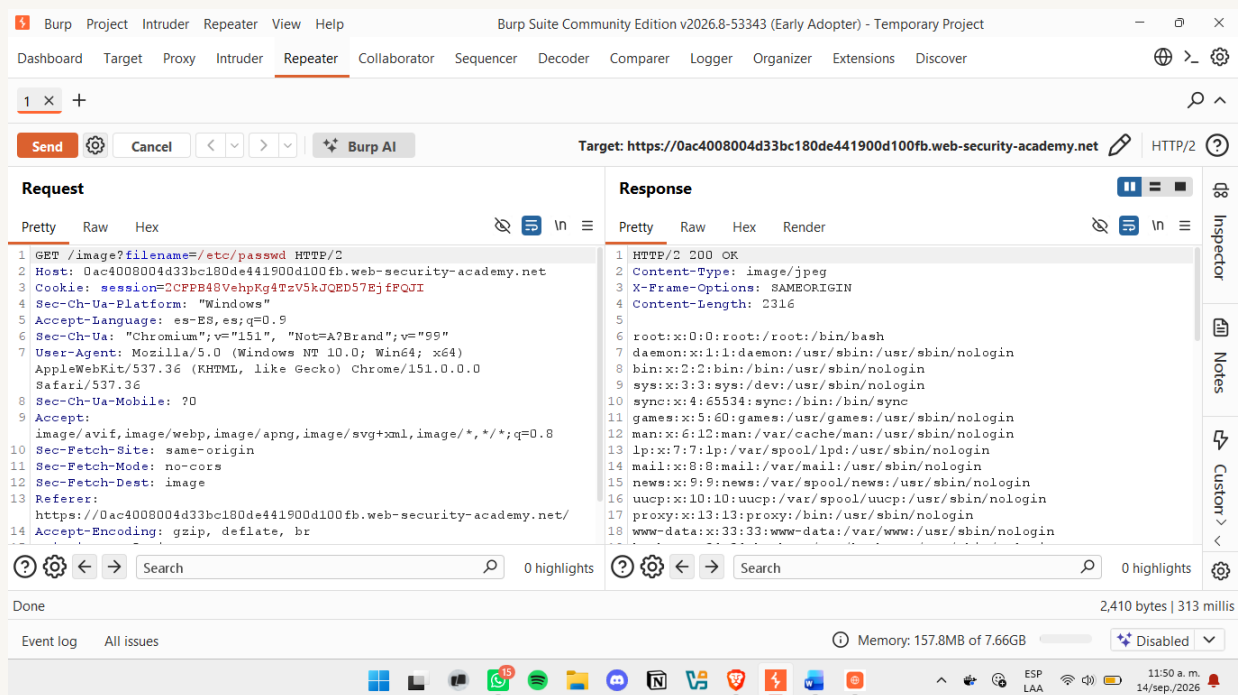
Response

```
1 GET /image?filename=72.jpg HTTP/2
2 Host: 0a79004d03819a68803ea3dd004500cc.web-security-academy.net
3 Cookie: session=DYbXatL82leF9ueIu6NNNT19pNuaMHpmw
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: es-ES, es; q=0.9
6 Sec-Ch-Ua: "Chromium"; v="151", "Not=A?Brand"; v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0
  Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept:
  image/avif, image/webp, image/apng, image/svg+xml, image/*; q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer:
  https://0a79004d03819a68803ea3dd004500cc.web-security-academy.net/
14 Accept-Encoding: gzip, deflate, br
```

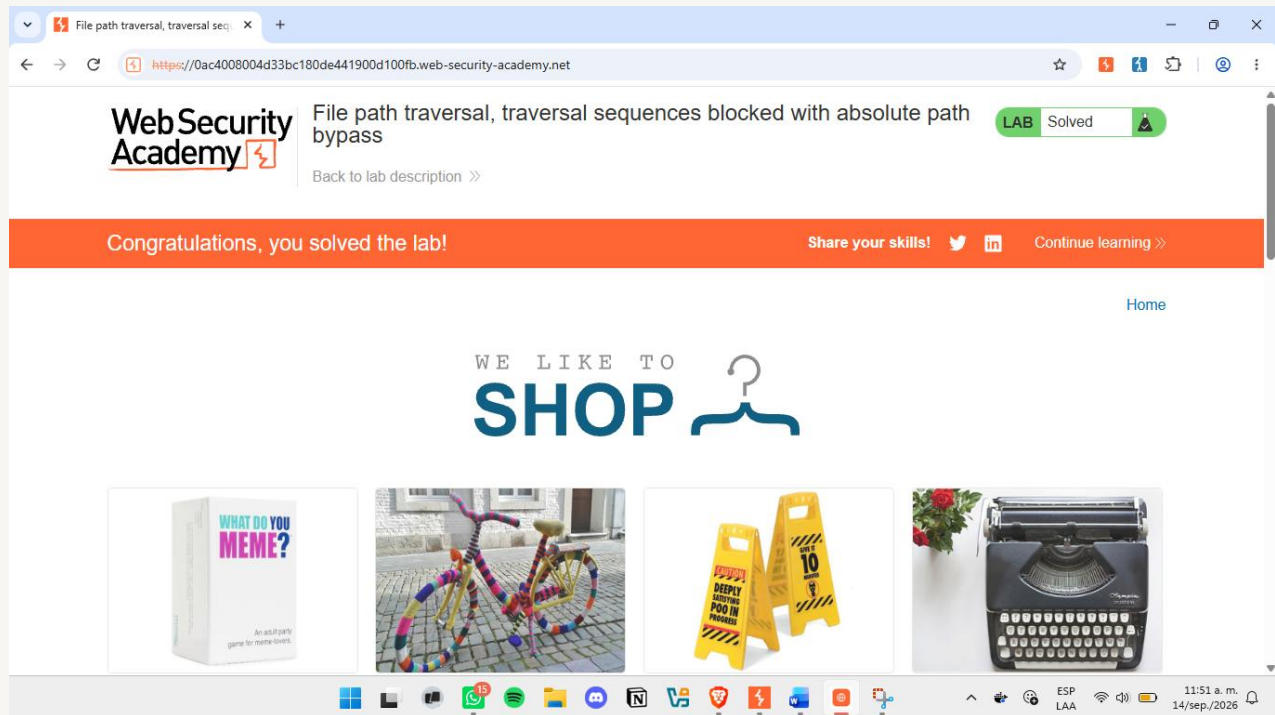
4. A diferencia del laboratorio anterior, en este caso el objetivo no era construir una secuencia de retroceso de directorio, sino que se sustituye por completo el valor del parámetro filename por la ruta absoluta del archivo objetivo, dado que la aplicación bloquea específicamente los patrones de traversal relativo



5. Se reenvió la petición modificada. El servidor respondió HTTP/2 200 OK, devolviendo en el cuerpo el contenido real de /etc/passwd, lo que confirmó que la ruta absoluta evadió el filtro anti-traversal implementado por la aplicación.



6. Se regresó a la pestaña de la tienda y se refrescó la página. La plataforma de PortSwigger reconoció la explotación exitosa y actualizó el estado del laboratorio de "Not solved" a "Solved".



Explicación del Payload

El vector de ataque utilizado fue simplemente `/etc/passwd`, colocado como valor completo del parámetro `filename`, en sustitución del nombre de archivo original. A diferencia del caso simple, este payload no contiene ninguna secuencia `"../"`, es directamente la ruta absoluta del archivo objetivo dentro del sistema de archivos del servidor.

Su efectividad depende de cómo el backend combina la carpeta base de imágenes con el valor recibido. Cuando esa combinación se realiza mediante una función de manejo de rutas del lenguaje de programación, en lugar de una simple concatenación de texto, es un comportamiento estándar en muchas de estas funciones que, si el segundo valor ya es una ruta absoluta, el resultado final sea exclusivamente esa ruta absoluta, descartando la carpeta de base por completo.

El filtro que la aplicación implementó contra `"../"` nunca llega a intervenir, porque el payload no contiene ese patrón y el problema no está en el filtro como tal, más bien en que fue diseñado para sólo bloquear un vector de ataque, dejando desprotegida la posibilidad de una ruta absoluta.

Mitigación recomendada

Las mismas medidas de fondo aplicables al caso simple siguen siendo válidas aquí, con un énfasis adicional en el motivo por el cual este filtro específico resultó insuficiente:

- **Evitar el paso directo de entradas a APIs del sistema de archivos:** en vez de dejar que el cliente mande cualquier ruta o nombre de archivo, usar un identificador aleatorio (UUID) que el servidor traduce internamente contra una base de datos para encontrar el archivo real.
- **Validación estricta por lista blanca, no por bloqueo de patrones:** en lugar de intentar detectar y bloquear secuencias específicas como "../" (un enfoque de blacklist que este laboratorio demuestra que es insuficiente), aceptar únicamente caracteres alfanuméricos y una extensión de archivo predefinida, rechazando cualquier valor que contenga "/", "\\\" o que no cumpla ese formato exacto, incluyendo las rutas absolutas.
- **Canonicalización y verificación de ruta base:** resolver la ruta absoluta canónica resultante mediante funciones nativas del lenguaje de desarrollo como por ejemplo, getCanonicalPath() en Java o os.path.realpath() / Path.resolve() en Python y verificar que dicho resultado comience estrictamente dentro del directorio base autorizado, sin importar si la entrada original parecía relativa o absoluta.
- **Principio de menor privilegio:** ejecutar el proceso del servidor con permisos mínimos, de forma que, aunque una ruta absoluta lograra evadir la validación de la aplicación, el sistema operativo continúe negando el acceso a directorios sensibles como /etc o /root.
- **Auditoría y pruebas específicas de bypass:** al probar defensas anti-traversal, incluir explícitamente casos de ruta absoluta, secuencias anidadas y codificaciones alternas dentro de las pruebas de penetración, en lugar de validar la corrección del filtro únicamente contra el vector de ataque original.

Referencias

MITRE Corporation. (2024). *CWE-22: Improper limitation of a pathname to a restricted directory ('Path Traversal')*. Common Weakness Enumeration. <https://cwe.mitre.org/data/definitions/22.html>

OWASP Foundation. (2025). *A01:2025 – Broken Access Control*. OWASP Top 10:2025. https://owasp.org/Top10/2025/A01_2025-Broken_Access_Control/

PortSwigger. (s.f.). *What is path traversal, and how to prevent it?* Web Security Academy. <https://portswigger.net/web-security/file-path-traversal>